



Bash
Bash

Matrix
Matrix

Hardening con Scripts en Linux y Windows

PARTE 1 – HARDENING EN LINUX

Usamos el script proporcionado y lo ejecutamos para llevar a cabo una serie de tareas de hardening contenidas en un unico archivo

```
GNU nano 7.2          hardening_script.sh *
#!/bin/bash

LOG="/var/log/hardening_iso.log"
echo "Inicio del hardening ISO 27001 - $(date)" >> $LOG

# Actualización del sistema
apt update && apt upgrade -y
echo "Sistema actualizado" >> $LOG

# Deshabilitar acceso SSH como root
sed -i 's/^#PermitRootLogin.*/PermitRootLogin no/' /etc/ssh/sshd_config
systemctl restart ssh
echo "Acceso SSH como root deshabilitado" >> $LOG

# Configurar firewall
ufw default deny incoming
ufw default allow outgoing
ufw allow ssh
ufw --force enable
echo "Firewall configurado" >> $LOG

# Deshabilitar servicio innecesario
systemctl stop avahi-daemon
systemctl disable avahi-daemon
echo "Servicio avahi-daemon deshabilitado" >> $LOG

# Proteger el archivo de log
chmod 600 $LOG
echo "Permisos del log asegurados" >> $LOG
```

Ejecución del script

```
victor@victor:~/scripts$ chmod +x hardening_script.sh
victor@victor:~/scripts$ ls -la hardening_script.sh
-rwxrwxr-x 1 victor victor 758 feb  3 13:11 hardening_script.sh
victor@victor:~/scripts$ sudo ./hardening_script.sh
[sudo] contraseña para victor:
Obj:1 http://security.ubuntu.com/ubuntu noble-security InRelease
Obj:2 http://es.archive.ubuntu.com/ubuntu noble InRelease
Obj:3 http://es.archive.ubuntu.com/ubuntu noble-updates InRelease
Des:4 https://ppa.launchpadcontent.net/landscape/self-hosted-24.04/ubuntu no
ble InRelease [18,1 kB]
Obj:5 http://es.archive.ubuntu.com/ubuntu noble-backports InRelease
Descargados 18,1 kB en 1s (30,3 kB/s)
Leyendo lista de paquetes... Hecho
Creando árbol de dependencias... Hecho
Leyendo la información de estado... Hecho
Se pueden actualizar 5 paquetes. Ejecute «apt list --upgradable» para verlos
.
Leyendo lista de paquetes... Hecho
Creando árbol de dependencias... Hecho
Leyendo la información de estado... Hecho
Calculando la actualización... Hecho
El paquete indicado a continuación se instaló de forma automática y ya no es
necesario.
  libllvm19
Utilice «sudo apt autoremove» para eliminarlo.
The following upgrades have been deferred due to phasing:
  ldap-utils libldap-common libldap2 python-apt-common python3-apt
0 actualizados, 0 nuevos se instalarán, 0 para eliminar y 5 no actualizados.
La política incoming predeterminada cambió a «deny»
(asegúrese de actualizar sus reglas consecuentemente)
La política outgoing predeterminada cambió a «allow»
(asegúrese de actualizar sus reglas consecuentemente)
Omitiendo adición de regla ya existente
Omitiendo adición de regla ya existente (v6)
El cortafuegos está activo y habilitado en el arranque del sistema
Stopping 'avahi-daemon.service', but its triggering units are still active:
avahi-daemon.socket
Disabling 'avahi-daemon.service', but its triggering units are still active:
avahi-daemon.socket
victor@victor:~/scripts$
```

1. ¿Qué función cumple la variable LOG en el script?

Almacena datos como el inicio del hardening, de manera que la fecha y hora se registran automáticamente al ejecutar el script, y nos permite añadir más datos de registro al mismo archivo.

2. Explica qué hace el comando apt update && apt upgrade -y y por qué es importante para la seguridad.

Descarga los repositorios actualizados de la distribución que estemos usando, e instala las actualizaciones descargadas con el fin de mantener nuestro sistema operativo actualizado, sobre todo en materia de seguridad.

3. ¿Qué se consigue al deshabilitar el acceso SSH como root?

Para evitar proporcionar control total sobre nuestro sistema a posibles atacantes, ya que SSH permite control absoluto de la máquina si no se securizan los privilegios correctamente.

4. Explica cómo funciona la configuración del firewall UFW aplicada en el script.

Deniegan el tráfico entrante, permiten el saliente, se permite SSH y se fuerza la habilitación del servicio para evitar que no se inicie en el arranque del sistema

5. ¿Por qué es recomendable deshabilitar servicios innecesarios como avahi-daemon?

Reducimos superficie de ataque, ya que a más servicios, más posibles puertas de entrada a nuestro sistema. También mitigamos posibles vulnerabilidades del servicio, evitamos que se pueda descubrir el servicio en red con herramientas como nmap, y finalmente ahorramos recursos que pueden ser necesarios.

6. ¿Qué significa establecer permisos 600 sobre el archivo de log?

Significa que solo el usuario propietario tiene permisos de lectura y escritura sobre ese archivo.

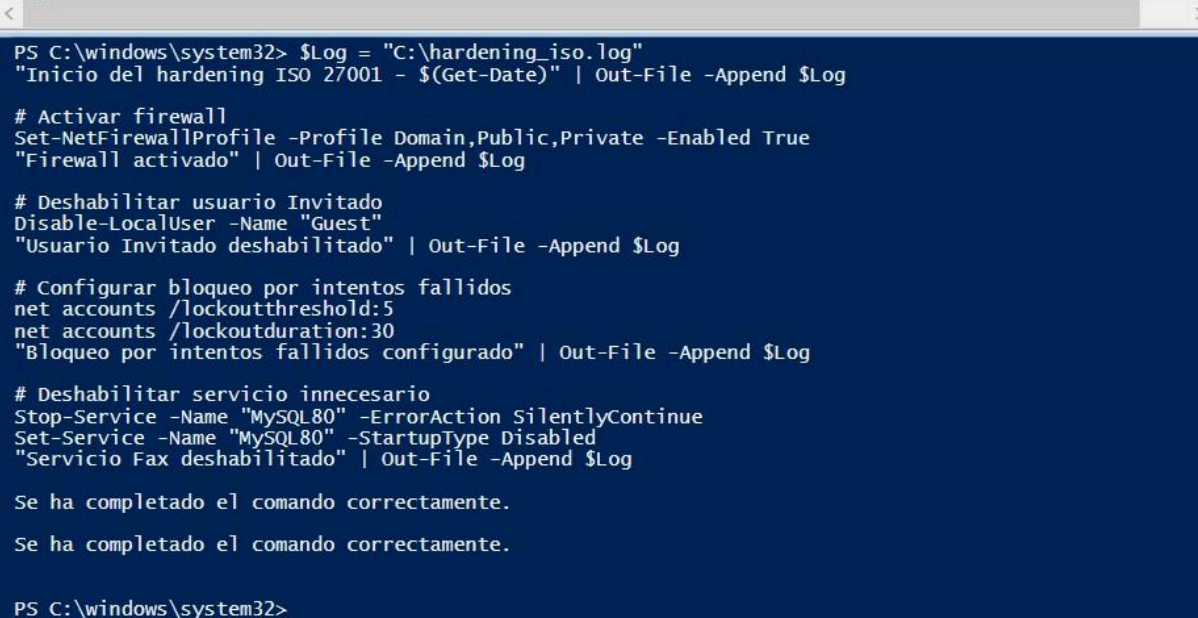
7. Indica qué controles de la ISO/IEC 27001 se cumplen con este script.

- Gestión de vulnerabilidades técnicas → `apt update && apt upgrade -y`
- Gestión de derechos de acceso privilegiado → `PermitRootLogin no`
- Controles de red (Seguridad en las comunicaciones) → `ufw`
- Registro y seguimiento (Logging) → `echo "... " >> $LOG`
- Protección de la información de registro → `chmod 600 $LOG`

PARTE 2 – HARDENING EN WINDOWS

Usamos el script proporcionado y lo ejecutamos para llevar a cabo una serie de tareas de hardening contenidas en un unico archivo

```
1 $Log = "C:\hardening_iso.log"
2 "Inicio del hardening ISO 27001 - $(Get-Date)" | Out-File -Append $Log
3
4 # Activar firewall
5 Set-NetFirewallProfile -Profile Domain,Public,Private -Enabled True
6 "Firewall activado" | Out-File -Append $Log
7
8 # Deshabilitar usuario Invitado
9 Disable-LocalUser -Name "Guest"
10 "Usuario Invitado deshabilitado" | Out-File -Append $Log
11
12 # Configurar bloqueo por intentos fallidos
13 net accounts /lockoutthreshold:5
14 net accounts /lockoutduration:30
15 "Bloqueo por intentos fallidos configurado" | Out-File -Append $Log
16
17 # Deshabilitar servicio innecesario
18 Stop-Service -Name "MySQL80" -ErrorAction SilentlyContinue
19 Set-Service -Name "MySQL80" -StartupType Disabled
20 "Servicio Fax deshabilitado" | Out-File -Append $Log
21
```



```
PS C:\windows\system32> $Log = "C:\hardening_iso.log"
"Inicio del hardening ISO 27001 - $(Get-Date)" | Out-File -Append $Log

# Activar firewall
Set-NetFirewallProfile -Profile Domain,Public,Private -Enabled True
"Firewall activado" | Out-File -Append $Log

# Deshabilitar usuario Invitado
Disable-LocalUser -Name "Guest"
"Usuario Invitado deshabilitado" | Out-File -Append $Log

# Configurar bloqueo por intentos fallidos
net accounts /lockoutthreshold:5
net accounts /lockoutduration:30
"Bloqueo por intentos fallidos configurado" | Out-File -Append $Log

# Deshabilitar servicio innecesario
Stop-Service -Name "MySQL80" -ErrorAction SilentlyContinue
Set-Service -Name "MySQL80" -StartupType Disabled
"Servicio Fax deshabilitado" | Out-File -Append $Log

Se ha completado el comando correctamente.

Se ha completado el comando correctamente.

PS C:\windows\system32>
```

1. ¿Para qué se utiliza el archivo hardening_iso.log?

Para almacenar un registro del proceso con las acciones realizadas y en que fecha y hora se han realizado.

2. Explica qué perfiles de red se ven afectados al activar el firewall.

Redes Privadas, Públicas y de Dominio.

3. ¿Por qué es importante deshabilitar el usuario Invitado?

El usuario invitado permite acceso anonimo y sin trazabilidad, puede servir como una entrada para atacantes, y en ocasiones el usuario invitado puede eludir politicas de seguridad.

4. Explica cómo funciona el bloqueo por intentos fallidos y qué riesgo mitiga.

Evita ataques de fuerza bruta al bloquear la cuenta durante un tiempo si se intenta acceder a ella con credenciales incorrectos

5. ¿Qué ventaja tiene deshabilitar servicios que no se utilizan?

Al igual que en Linux, reducimos superficie de ataque, ya que a más servicios, más posibles puertas de entrada a nuestro sistema. También mitigamos posibles vulnerabilidades del servicio, evitamos que se pueda descubrir el servicio en red con herramientas como nmap, y finalmente ahorramos recursos que pueden ser necesarios.

6. Indica qué controles de la ISO/IEC 27001 se cumplen con este script.

- Gestión de vulnerabilidades técnicas y seguridad en las comunicaciones →
`Set-NetFirewallProfile ... -Enabled True`
- Gestión de cuentas de usuario → `Disable-LocalUser -Name "Guest"`
- Sistema de gestión de contraseñas y autenticación → `net accounts`
`/lockoutthreshold:5 /lockoutduration:30`
- Registro y monitorización → `... | Out-File -Append $Log`
- Seguridad operativa y reducción de superficie de ataque → `Stop-Service ...`
`Set-Service ... Disabled`